

DNS hijacking, or DNS redirection, is the practice of subverting the resolution of Domain Name System (DNS) queries. This can be achieved by malware that overrides a computer's TCP/IP configuration to point at a rogue DNS server under the control of an attacker, or through modifying the behaviour of a trusted DNS server so that it does not comply with internet standards.

These modifications may be made for malicious purposes such as phishing, for self-serving purposes by Internet service providers (ISPs), by public/router-based online DNS server providers to direct users' web traffic to the ISP's own web servers where advertisements can be served, statistics collected, or other purposes of the ISP; and by DNS service providers to block access to selected domains as a form of censorship.

Technical background

One of the functions of a DNS server is to translate a domain name into an IP address that applications need to connect to an Internet resource such as a website. This functionality is defined in various formal internet standards that define the protocol in considerable detail. DNS servers are implicitly trusted by internet-facing computers and users to correctly resolve names to the actual addresses that are registered by the owners of an internet domain.

Rogue DNS server

A rogue DNS server translates domain names of desirable websites (search engines, banks, brokers, etc.) into IP addresses of sites with unintended content, even malicious websites. Most users depend on DNS servers automatically assigned by their ISPs. A router's assigned DNS servers can also be altered through the remote exploitation of a vulnerability within the router's firmware. When a user tries to visit a website, they are instead sent to a fake page that appears to use the same domain. This attack is termed pharming. If the site they are redirected to is a malicious website, masquerading as a legitimate website, in order to

fraudulently obtain sensitive information, it is called phishing.

Manipulation by ISPs

A number of consumer ISPs such as AT&T, Cablevision's Optimum Online, CenturyLink, Cox Communications, RCN, Rogers, Charter Communications (Spectrum), Plusnet, Verizon, Sprint, T-Mobile US, Virgin Media, Frontier Communications, Bell Internet, Deutsche Telekom AG, Optus, Mediacom, ONO, TalkTalk, Bigpond (Telstra), TTNET, Türksat, and all Indonesian customer ISPs use or used DNS hijacking for their own purposes, such as displaying advertisements or collecting statistics. Dutch ISPs XS4ALL and Ziggo use DNS hijacking by court order: they were ordered to block access to The Pirate Bay and display a warning page while all legal customer ISPs in Indonesia do DNS hijacking to comply with the National DNS law which requires every customer Indonesian ISP to hijack port 53 and redirect it to their own server to block website that are listed in Trustpositif by Kominfo under the Internet Sehat campaign. These practices directly violate the RFC standards for DNS (NXDOMAIN - Non eXistent Domain) responses and introduce security vulnerabilities such as cross-site scripting. However, the effectiveness of ISP-level DNS hijacking has substantially declined due to the widespread adoption of encrypted DNS protocols, specifically DNS over HTTPS (DoH) and DNS over TLS (DoT). Modern web browsers and operating systems increasingly route queries through these encrypted channels by default, preventing ISPs from intercepting or manipulating DNS responses.

The concern with DNS hijacking involves this hijacking of the NXDOMAIN response. Internet and intranet applications rely on the NXDOMAIN response to describe the condition where the DNS has no entry for the specified host. If one were to query the invalid domain name (for example `www.example.invalid`), one should get an NXDOMAIN response – informing the application that the name is invalid and taking the appropriate action (for example, displaying an error or not attempting to connect to the server). However, if the domain name is queried

on one of these non-compliant ISPs, one would always receive a fake IP address belonging to the ISP. In a web browser, this behavior can be annoying as connections to this IP address display the ISP redirect page of the provider, sometimes with advertising, instead of a proper error message. However, other applications that rely on the NXDOMAIN error will instead attempt to initiate connections to this spoofed IP address, potentially exposing sensitive information.

Examples of functionality that breaks when an ISP hijacks DNS:

Roaming laptops that are members of a Windows Server domain will falsely be led to believe that they are back on a corporate network because resources such as domain controllers, email servers and other infrastructure will appear to be available. Applications will therefore attempt to initiate connections to these corporate servers, but fail, resulting in degraded performance, unnecessary traffic on the Internet connection and timeouts.

Many small office and home networks do not have their own DNS server, relying instead on broadcast name resolution. Many versions of Microsoft Windows default to prioritizing DNS name resolution above NetBIOS name resolution broadcasts; therefore, when an ISP DNS server returns a (technically valid) IP address for the name of the desired computer on the LAN, the connecting computer uses this incorrect IP address and inevitably fails to connect to the desired computer on the LAN. Workarounds include using the correct IP address instead of the computer name, or changing the DhcpNodeType registry value to change name resolution service ordering.

Browsers such as Firefox no longer have their "Browse By Name" functionality (where keywords typed in the address bar take users to the closest matching site).

The local DNS client built into modern operating systems will cache results of DNS searches for performance reasons. If a client switches between a home network and a VPN, false entries may remain cached, thereby creating a service outage on the VPN connection.

DNSBL anti-spam solutions rely on DNS; false DNS results therefore interfere with their operation.

Confidential user data might be leaked by applications that are tricked by the ISP into believing that the servers they wish to connect to are available.

User choice over which search engine to consult in the event of a URL being mistyped in a browser is removed as the ISP determines what search results are displayed to the user.

Computers configured to use a split tunnel with a VPN connection will stop working because intranet names that should not be resolved outside the tunnel over the public Internet will start resolving to fictitious addresses, instead of resolving correctly over the VPN tunnel on a private DNS server when an NXDOMAIN response is received from the Internet. For example, a mail client attempting to resolve the DNS A record for an internal mail server may receive a false DNS response that directed it to a paid-results web server, with messages queued for delivery for days while retransmission was attempted in vain.

It breaks Web Proxy Autodiscovery Protocol (WPAD) by leading web browsers to believe incorrectly that the ISP has a proxy server configured.

It breaks monitoring software. For example, if one periodically contacts a server to determine its health, a monitor will never see a failure unless the monitor tries to verify the server's cryptographic key.

In some, but not most cases, the ISPs provide subscriber-configurable settings to disable hijacking of NXDOMAIN responses. Correctly implemented, such a setting reverts DNS to standard behavior. Other ISPs, however, instead use a web browser cookie to store the preference. In this case, the underlying behavior is not resolved: DNS queries continue to be redirected, while the ISP redirect page is replaced with a counterfeit DNS error page. Applications other than web browsers cannot be opted out of the scheme using cookies as the opt-out targets only the HTTP protocol, when the scheme is actually implemented in the protocol-neutral DNS.

Response

In the UK, the Information Commissioner's Office has acknowledged that the practice of involuntary DNS hijacking contravenes PECR, and EC Directive 95/46 on Data Protection which require explicit consent for processing of communication traffic. In Germany, in 2019 it was revealed that the Deutsche Telekom AG not only manipulated their DNS servers, but also transmitted network traffic (such as non-secure cookies when users did not use HTTPS) to a third-party company because the web portal T-Online, at which users were redirected due to the DNS manipulation, was not (any more) owned by the Deutsche Telekom. After a user filed a criminal complaint, the Deutsche Telekom stopped further DNS manipulations.

ICANN, the international body responsible for administering top-level domain names, has published a memorandum highlighting its concerns, and affirming: ICANN strongly discourages the use of DNS redirection, wildcards, synthesized responses and any other form of NXDOMAIN substitution in existing gTLDs, ccTLDs and any other level in the DNS tree for registry-class domain names.

Remedy

End users, dissatisfied with poor "opt-out" options like cookies, have responded to the controversy by finding ways to avoid spoofed NXDOMAIN responses. DNS software such as BIND and Dnsmasq offer options to filter results, and can be run from a gateway or router to protect an entire network. Google, among others, run open DNS servers that currently do not return spoofed results. So a user could use Google Public DNS instead of their ISP's DNS servers if they are willing to accept that they use the service under Google's privacy policy and potentially be exposed to another method by which Google can track the user. One limitation of this approach is that some providers block or rewrite outside DNS requests. OpenDNS,

owned by Cisco, is a similar popular service which does not alter NXDOMAIN responses.

Google in April 2016 launched DNS-over-HTTPS service. This scheme can overcome the limitations of the legacy DNS protocol. It performs remote DNSSEC check and transfers the results in a secure HTTPS tunnel.

There are also application-level work-arounds, such as the NoRedirect Firefox extension, that mitigate some of the behavior. An approach like that only fixes one application (in this example, Firefox) and will not address any other issues caused. Website owners may be able to fool some hijackers by using certain DNS settings. For example, setting a TXT record of "unused" on their wildcard address (e.g. *.example.com). Alternatively, they can try setting the CNAME of the wildcard to "example.invalid", making use of the fact that ".invalid" is guaranteed not to exist per the RFC. The limitation of that approach is that it only prevents hijacking on those particular domains, but it may address some VPN security issues caused by DNS hijacking.

See also

Captive portal

DNSChanger

DNS rebinding

DNS spoofing

Dynamic Host Configuration Protocol

Pharming

Point-to-Point Protocol

Spoofing attack

TCP reset attack

Trojan.Win32.DNSChanger

== References ==